DJS ISACA

D3COY 1.0

TEAM NAME :

CTRL FREAKS

COLLEGE NAME :

CHENNAI INSTITUTE OF TECHNOLOGY

Chennai, Tamil Nadu

PROBLEM STATEMENT :

Identity Drift Detection in Autonomous AI Agents

AI agents carry their own tokens and permissions. Access control checks whether an identity is allowed to act — never whether it still behaves like its role. A hidden prompt, a poisoned tool or a stolen token can hijack an agent while every check passes.

TEAM MEMBER DETAILS :

01	KAMESHWARAN B	+91 72008 05541
02	VS ANISHWATH	+91 88255 14383
03	LIKITH KRISHNA J	+91 92823 26251
04	SRI AARUSH TEJ	+91 86376 61221

©2026-27

PROPOSED SOLUTION

PROBLEMS FACED

Prompt Injection
hidden instruction in a document

→ Agent leaks data — token still valid

Poisoned Tool
malicious plugin / API response

→ Tool calls redirected to attacker

Stolen Token
credentials replayed by attacker

→ Attacker acts as a trusted agent

Limitations of existing solutions

- **IAM checks the token,** never the behaviour
- **Static RBAC** can't see a role drifting
- **Anomaly tools** give black-box scores
- **Kill-switch response** halts the whole fleet

SentinelTrace *watches what an agent* ***does*** *— not just what it is allowed to do.*

Agent Fleet
- Agents A · B · C
- Docs, tools & APIs
- Signed role contract
- Owner-approved scope

→

Capture
- Every action logged
- Trusted / untrusted tag
- Provenance lineage
- No agent code change

→

Behaviour AI
- Per-role sequence model
- Embedding similarity
- Resource-access graph
- Rolling-window baseline

→

Drift Score
- Role conformance
- Behavioural novelty
- Untrusted-content signal
- Fused into 0 – 100

↓

Chain Risk
Agent A calls B → B inherits a share of A's risk

←

Explain
Names the exact action, mismatch and trigger event

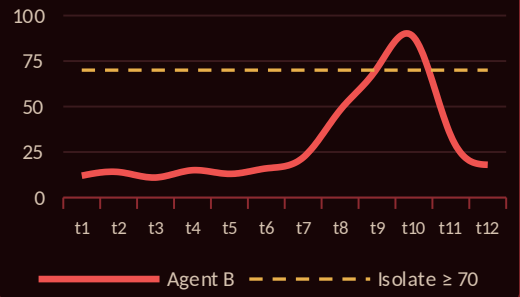
←

Containment
- LOG
- APPROVE
- ISOLATE

←

Dashboard
Live scores, reasons & full audit trail

Live Drift Score — Agent B



Attack caught in 3 steps

1. **Reads untrusted PDF**
   provenance: untrusted
2. **Calls export_data()**
   outside role contract
3. **Sends to unknown domain**
   new access-graph edge

→ Score 88 → auto-isolated

Novelty & Uniqueness

- Behaviour, not just tokens
- Chain-aware risk propagation
- Plain-language explanations
- Graduated, not kill-switch

TECHNICAL APPROACH

DJS ISACA

D3COY 1.0

ZONE 1 Agent Ecosystem

- **Agent A** role: Research
- **Agent B** role: Finance
- **Agent C** role: Ops

Inputs

Docs · Tools · APIs

- **Role Contract** signed: tools, data, flows

ZONE 2 Telemetry Layer

- **Action Interceptor** SDK hook / proxy on every call
- **Event Log** time-stamped JSONL stream
- **Provenance Tagger** trusted vs untrusted source
- **Feature Builder** n-gram sequences + embeddings

ZONE 3 Detection Engine

- **Role Conformance** action vs signed contract
- **Sequence Anomaly** Isolation Forest / OC-SVM
- **Semantic Drift** sentence-transformers + FAISS
- **Access Graph** new edge = novelty
- **Rule Layer** sensitive act ≤ N steps after untrusted read

ZONE 4 Scoring & Response

Risk Fusion (0–100)

$$R = 0.40 \cdot \text{Role} + 0.35 \cdot \text{Novelty} + 0.25 \cdot \text{Provenance}$$

$+ \alpha \cdot$ upstream risk (propagation)

OPA Policy Bands

- 0–39 LOG
- 40–69 APPROVE
- 70–100 ISOLATE

- **Streamlit Dashboard** live scores + reasons
- **Audit Log** every score & signal kept

containment fed back to the agent: log · pause for approval · sandbox

Implementation Process

1. **Simulate** — 3–5 agents · normal + injected-attack logs
2. **Baseline** — fit per-role sequence & access models
3. **Score** — fuse 3 signals + rule layer → 0–100
4. **Respond** — OPA bands + risk propagation
5. **Demo** — clean run vs attack run, side by side

TECH STACK

- **Python** core
- **sklearn** IF / OC-SVM
- **PyOD** outliers
- **SBERT** embeddings
- **FAISS** vector search
- **OPA** policy
- **Plotly** charts
- **Streamlit** dashboard

©2026-27

FEASIBILITY AND VIABILITY

D3COY 1.0

Feasibility Analysis

Technical Feasibility

Proven open-source ML only — Isolation Forest, One-Class SVM, SBERT, FAISS. No custom training, no GPU.

Economical Feasibility

₹0 licence cost — 100% open-source. Prototype runs on one CPU-only laptop (8 GB RAM); a pilot needs one small VM.

Operational Feasibility

Sidecar beside existing IAM — agents only need a logging hook. Built in 24 hrs with 3–5 simulated agents.

Viability / Scalability

Deployment Viability

Docker sidecar that scales out per fleet; one hook plugs into any agent framework.

Economic Viability

No cloud lock-in, no per-seat licences; CPU-only scoring stays cheap at scale.

Security Viability

Logs stay on-prem, only drift patterns leave; every decision is audit-logged.

Challenges & Mitigations

Challenges	Mitigations
Cold start for brand-new agents	Role-template baseline pooled from similar agents
False positives stop real work	Graduated response: log → approve → isolate
Legitimate behaviour evolves	Rolling-window re-baselining keeps models current
One weak signal is noisy	Multi-signal fusion — no single signal decides

SWOT ANALYSIS

Strengths

- Identity + behaviour in one score
- Explainable, fully open-source
- Works with any agent framework

Weaknesses

- Needs history to baseline
- Demo uses synthetic logs
- Weights need per-org tuning

Opportunities

- Prompt injection is #1 in OWASP Top 10 for LLM apps
- Agent fleets growing fast
- New AI-governance rules

Threats

- Slow, low-noise attackers
- Big vendors adding features
- Alert fatigue if mis-tuned

IMPACTS AND BENEFITS

Potential Impact on Target Audience

Enterprise SOC Teams
Fewer, clearer alerts that name the exact action and trigger.

AI / MLOps Teams
Ship autonomous agents with a behavioural safety net.

BFSI & Healthcare
Stops silent data exfiltration from regulated systems.

Govt & Defence IT
Catches hijacked agents even with valid credentials.

Impact on Target Organisation

SentinelTrace prototype

1. **Closes the blind spot** — flags hijacked agents whose tokens are still valid
2. **Stops injection exfiltration** — untrusted doc → sensitive action → external host
3. **Contains only the bad agent** — the rest of the fleet keeps working
4. **Audit-ready AI governance** — every score and signal is logged

	✕ Traditional IAM	✓ SentinelTrace
What it checks	Token & permissions only	Token + live behaviour
Hijacked agent, valid token	Passes silently	Flagged in real time
Alert quality	None / black-box score	Plain-language, per signal
Response	Revoke all, manually	Log → approve → isolate
Multi-agent chains	Blind	Risk propagates downstream

Key Benefits

- **Cuts alert fatigue** — act on an alert, not triage it
- **Real-time detection** — every action scored live
- **Keeps work moving** — only the bad agent is isolated
- **Audit-ready** — full trail for AI governance
- **Low cost** — open-source, CPU-only
- **Framework-agnostic** — one hook, any agent stack

Aligned with **OWASP LLM Top 10** · **NIST AI RMF** · **DPDP Act 2023** · **SDG 9 & 16**

USP AND FUTURE SCOPE

UNIQUE SELLING PROPOSITION

Most tools ask ***"is this token valid?"***
SentinelTrace asks ***"is this agent still acting like its role?"***

Behaviour-aware identity
live actions measured against a signed role contract

Chain-aware
one compromised agent can't hide behind another's clean record

Explainable by design
every alert names the action, mismatch and trigger

Graduated containment
log → approve → isolate, never an all-or-nothing kill switch

Open & pluggable
100% open-source; swap any signal without a rebuild



A calls B calls C — each inherits a share of upstream risk

FUTURE SCOPE — *from hackathon to platform*

24 hrs — Phase 0 · Hackathon
3–5 simulated agents · 3 fused signals + rule layer · live Streamlit dashboard

Month 1–3 — Phase 1 · Pilot
1 real agent fleet · tune thresholds on real data · target < 5% false-positive rate

Month 4–6 — Phase 2 · Integrate
MCP & A2A tool-call hooks · LangChain / AutoGen adapters · ready-made OPA policy packs

Month 7–12 — Phase 3 · Standardise
Adopt emerging agent-identity standards (OAuth, SPIFFE-style workload IDs) instead of a custom role format

Year 2 — Phase 4 · Federate
Cross-org threat intel: share drift patterns, never raw logs · SaaS + on-prem editions

TARGET METRICS

< 1 s	< 5 %	100 %	0
scoring per action	false positives post-pilot	alerts explained	raw logs shared